

SDK / стек

Параметр	Значение
Название приложения	888Casino
Android Gradle Plugin	8.7.3
minSdk	26
targetSdk	36
Kotlin	да, 2.0.21
Web View	да
Custom Tabs	нет
Рекламные сети	нет
Аналитика	нет
Permissions	android.permission.INTERNET, android.permission.ACCESS_WIFI_STATE, android.permission.ACCESS_NETWORK_STATE, com.luckyreads.bookshelf.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION, com.android.vending.CHECK_LICENSE
Libraries	Kotlin 2.0.21, kotlinx-coroutines 1.7.3, OkHttp 4.12.0, AndroidX (AppCompat, Activity, ConstraintLayout, Core/Core-KTX, Fragment, Lifecycle, Room, RecyclerView, ViewPager2, Emoji2, Startup, ProfileInstaller, CardView, CoordinatorLayout, DrawerLayout, Transition, Vectordrawable, SavedState, SQLite), Google Material Components 1.12.0, Pairip licensecheck (com.pairip.licensecheck)
Подозрительные домены	blue-limit-83a7.serg-savwork.workers.dev
SharedPreferences	файл prefs «cfg»: ключ «rurl» — сохранённый URL после редиректа с Cloudflare Worker; при повторном запуске сразу открывается через Intent VIEW
Есть ли клоака	да
Подозрительные слова	casino, User-Agent, rurl, redirect, license check, white page, webview url, workers.dev

Проверка домена: blue-limit-83a7.serg-savwork.workers.dev

Параметр / движок	Значение / вердикт
Домен	blue-limit-83a7.serg-savwork.workers.dev
VirusTotal URL	https://www.virustotal.com/gui/domain/blue-limit-83a7.serg-savwork.workers.dev
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
0xSI_f33d	Unrated
Abusix	Unrated
Acronis	Unrated
ADMINUSLabs	Unrated
AILabs (MONITORAPP)	Unrated
AlienVault	Unrated
alphaMountain.ai	Unrated
AlphaSOC	Unrated
Antiy-AVL	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
BitDefender	Unrated
Bkav	Unrated
Blueliv	Unrated
Certego	Unrated

Параметр / движок	Значение / вердикт
ChainPatrol	Unrated
Chong Lua Dao	Unrated
CINS Army	Unrated
Cluster25	Unrated
CMC Threat Intelligence	Unrated
CRDF	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
CTX AI	Unrated
Cyan	Unrated
Cyble	Unrated
CyRadar	Unrated
desenmascara.me	Unrated
DNS8	Unrated
Dr.Web	Unrated
EmergingThreats	Unrated
Emsisoft	Unrated
Ermes	Unrated
ESET	Unrated
ESTsecurity	Unrated
Forcepoint ThreatSeeker	Unrated
Fortinet	Unrated
Fortra	Unrated
G-Data	Unrated
GCP Abuse Intelligence	Unrated
Google Safe Browsing	Unrated
GreenSnow	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Heimdal Security	Unrated
Hunt.io Intelligence	Unrated
IPsum	Unrated
Juniper Networks	Unrated
Kaspersky	Unrated
LevelBlue	Unrated
Lionic	Unrated
Lumu	Unrated
Malwared	Unrated
MalwarePatrol	Unrated
MalwareURL	Unrated
Mimecast	Unrated
Netcraft	Unrated
OpenPhish	Unrated
PhishFort	Unrated
Phishing Database	Unrated

Параметр / движок	Значение / вердикт
Phishtank	Unrated
PREBYTES	Unrated
PrecisionSec	Unrated
Quick Heal	Unrated
Quttera	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
Scantitan	Unrated
SCUMWARE.org	Unrated
Seclookup	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
Sophos	Unrated
StopForumSpam	Unrated
Sucuri SiteCheck	Unrated
ThreatHive	Unrated
URLhaus	Unrated
URLQuery	Unrated
Viettel Threat Intelligence	Unrated
VIPRE	Unrated
ViriBack	Unrated
VX Vault	Unrated
Webroot	Unrated
Xcitium Verdict Cloud	Unrated
Yandex Safebrowsing	Unrated
ZeroCERT	Unrated
ZeroFox	Unrated
Куда редиректит	нет (без редиректа)
Что выводит (кратко)	{"status":"ok","version":"1.0.0","ts":1785327811984}
Где припаркован	регистратор: CloudFlare, Inc.

Как работает клоака

В начале

Снаружи в Google Play приложение продаётся как «888Casino» (разработчик Zimvoler, пакет com.luckyreads.bookshelf). По названию это казино-бренд, но внутри APK лежит совсем другой продукт: локальная HTML-«читалка» классики под именем «Lucky Reads» (около 100 произведений, поиск, Lucky Pick) — её показывают в WebView (встроенном окне браузера внутри приложения).

Обман в том, что при первом запуске приложение не сразу открывает эту библиотеку. Сначала оно тихо спрашивает свой сервер на Cloudflare Workers (blue-limit-83a7.serg-savwork.workers.dev), можно ли этому пользователю показать «белую» читалку или увести его наружу. Сервер решает через HTTP-редирект (перенаправление на другой адрес): если ответа с другим URL нет — остаётся безопасная маска; если URL сменился — это «боевая» ссылка.

«Нужный» пользователь в итоге уходит из приложения во внешний браузер (через обычный Intent VIEW — системное «открыть ссылку») на динамический URL, который прислал Worker. Конкретный финальный сайт (казино/лендинг/оффер) в APK не зашит: он приезжает только с сервера. На момент проверки пайплайна Worker отвечал JSON без редиректа — то есть «боевой» URL включается сервером выборочно.

Кому что показывают

Белая страница / обычный режим. Её видит тот, кому Worker не делает редирект (типично: проверка магазина, бот, «нецелевой» IP/страна — решение на стороне сервера). Приложение показывает WebView с локальным файлом `file:///android_asset/index.html` — полноценный офлайн-каталог «Lucky Reads» (Browse All / Lucky Pick / Search). Никакой рекламы и никакого внешнего гемблинг-URL на экране нет. То же происходит при ошибке сети или если внешний браузер не удалось открыть.

Чёрный / боевой режим. Если после запроса к Worker итоговый URL отличается от исходного (сервер сделал редирект), приложение сохраняет этот URL в SharedPreferences под ключом «rurl» и сразу открывает его во внешнем браузере. WebView при этом прячут. Пользователь оказывается на динамическом лендинге/оффере, который выбрал сервер — не на «читалке».

Как приложение решает, кого куда пустить

1) Свой API на Cloudflare Worker. Что смотрит: GET

`https://blue-limit-83a7.serg-savwork.workers.dev/?app=com.luckyreads.bookshelf` (OkHttp следует редиректам). Условие: сравнить исходный URL запроса и финальный URL ответа. Результат: совпали → белая HTML-читалка; отличаются → сохранить финальный URL и открыть снаружи.

2) User-Agent (строка браузера устройства). Что смотрит: заголовок User-Agent = `WebSettings.getDefaultUserAgent` (как у системного WebView). Условие: сервер может отличить «живой» Android WebView от бота/скрипта. Результат: на клиенте только передача; фильтр — на Worker (в коде не видно).

3) Модель устройства. Что смотрит: кастомный заголовок `X-Device-Model = Build.MODEL`. Условие/результат: дополнительный сигнал для серверной фильтрации (эмулятор vs реальное устройство) — логика только на бэкенде.

4) Язык / Accept-Language. Что смотрит: заголовок жёстко `en-US,en;q=0.9` (не берётся из настроек телефона). Условие: сервер видит «английский» клиент. Результат: вместе с IP запроса это типичный набор для geo/traffic-фильтров на Worker; в APK отдельных проверок страны нет.

5) IP / гео / VPN. Что смотрит: в клиентском коде нет списка стран и нет VPN-детекта. Условие и фильтр, если есть, — по IP на стороне Cloudflare Worker (в коде не видно). Результат: клиент просто сравнивает URL.

6) SharedPreferences «cfg» / ключ «rurl». Что смотрит: уже сохранённая боевая ссылка. Условие: строка не пустая. Результат: пропуск повторного запроса к Worker и сразу внешний Intent на этот URL (закрепление «чёрного» режима после первого успешного редиректа).

7) Pairip license check. Что смотрит: лицензия Google Play (CHECK_LICENSE) при старте Application. Условие: установка из Play. Результат: защита/привязка к магазину, а не выбор белый/чёрный контент.

Цепочка по шагам

Шаг 1. Пользователь открывает приложение → стартует MainActivity с полноэкранным WebView → система готова либо показать локальную читалку, либо увести наружу.

Шаг 2. Читаются SharedPreferences «cfg» → ищется ключ «rurl» → если URL уже сохранён, сразу вызывается внешнее открытие ссылки (без нового запроса к серверу).

Шаг 3. Если «rurl» пуст → OkHttp собирает GET на Cloudflare Worker с `?app=com.luckyreads.bookshelf` → сервер получает package name и может выбрать сценарий под это приложение.

Шаг 4. К запросу добавляют заголовки `X-Device-Model`, `Accept-Language=en-US`, User-Agent WebView → сервер видит «портрет» устройства → может отфильтровать ботов/модерацию/нужную гео.

Шаг 5. Worker отвечает: либо 200 без смены URL (белый), либо HTTP-редирект на другой адрес (боевой) → OkHttp следует редиректам → клиент сравнивает исходный и финальный URL.

Шаг 6. URL совпали → вызывается `v()`: WebView показывает `file:///android_asset/index.html` («Lucky Reads») → пользователь видит каталог классики.

Шаг 7. URL различаются → новый адрес пишется в «rurl» → вызывается `w()`: WebView скрывают, стартует Intent VIEW → человек уходит во внешний браузер на динамический оффер/лендинг.

Шаг 8. Сеть упала или Intent не открылся → запасной путь снова показывает белую локальную HTML-читалку → модератор/сбой не видит «боевой» контент.

Шаг 9. При следующем запуске, если «rurl» уже есть → шаги 3–5 пропускаются → сразу снова открывается сохранённый внешний URL.

Технические уловки

XOR-шифрование строк. URL Worker, имя prefs («cfg»), ключ («rurl»), заголовки (User-Agent, Accept-Language, X-Device-Model), query «?app=» и путь белой страницы file:///android_asset/index.html лежат в APK как байтовые массивы и расшифровываются методом MainActivity.t() ключом [193,30,135,90]. Зачем спрятали: чтобы простой поиск по строкам APK не выдал управляющий домен и схему.

Решение «белый/чёрный» по факту редиректа, а не по JSON. Клиент не парсит тело ответа (сейчас Worker отдаёт {"status":"ok","version":"1.0.0",...}). Он сравнивает исходный и финальный URL после follow-redirects OkHttp. Зачем: логика фильтра целиком на сервере, в APK нет списков стран/офферов.

WebView только для белой маски; боевой трафик — через Intent VIEW. В манифесте/коде Custom Tabs нет. Боевой URL уходит в системный браузер, а не остаётся внутри приложения — сложнее связать оффер с APK при поверхностном просмотре UI.

usesCleartextTraffic=true + JS/DOM Storage в WebView. Разрешён небезопасный HTTP и полноценный веб-рантайм для белой страницы. Pairip/LicenseActivity — обёртка Play license, не часть выбора оффера.

Роль подозрительных доменов

blue-limit-83a7.serg-savwork.workers.dev — единственный кастомный хост из domain_checks. Он появляется на шагах 3–5 цепочки: это «мозг» решения белый/чёрный. Приложение шлёт на него GET с ?app=com.luckyreads.bookshelf и заголовками устройства. На момент проверки пайплайна домен отвечал 200 без редиректа JSON {"status":"ok","version":"1.0.0","ts":1785327811984}, VirusTotal 0/91 (все движки Unrated), регистратор CloudFlare, Inc. Финальный лендинг с него не обязан совпадать с самим workers.dev — OkHttp может уйти на любой Location после редиректа, когда сервер включит «боевой» режим.

Финал для пользователя

После всех проверок есть два исхода. «Нецелевой» / модераторский трафик остаётся внутри приложения на офлайн-читалке «Lucky Reads». «Боевой» пользователь уходит во внешний браузер на динамический URL из редиректа Worker; сам URL в APK не зашит. На снимке domain_checks редиректа не было (белая конфигурация), но код клиента однозначно ждёт смену URL. По бренду стор (888Casino) цель похожа на казино/гемблинг-оффер, но точный финальный сайт виден только в рантайм-ответе сервера (или в уже сохранённом «rurl» на устройстве).